GitLab Agentic AI for Security Workflows

RSA After-Hours

GitLab Copyright

GitLab

Fernando Diaz

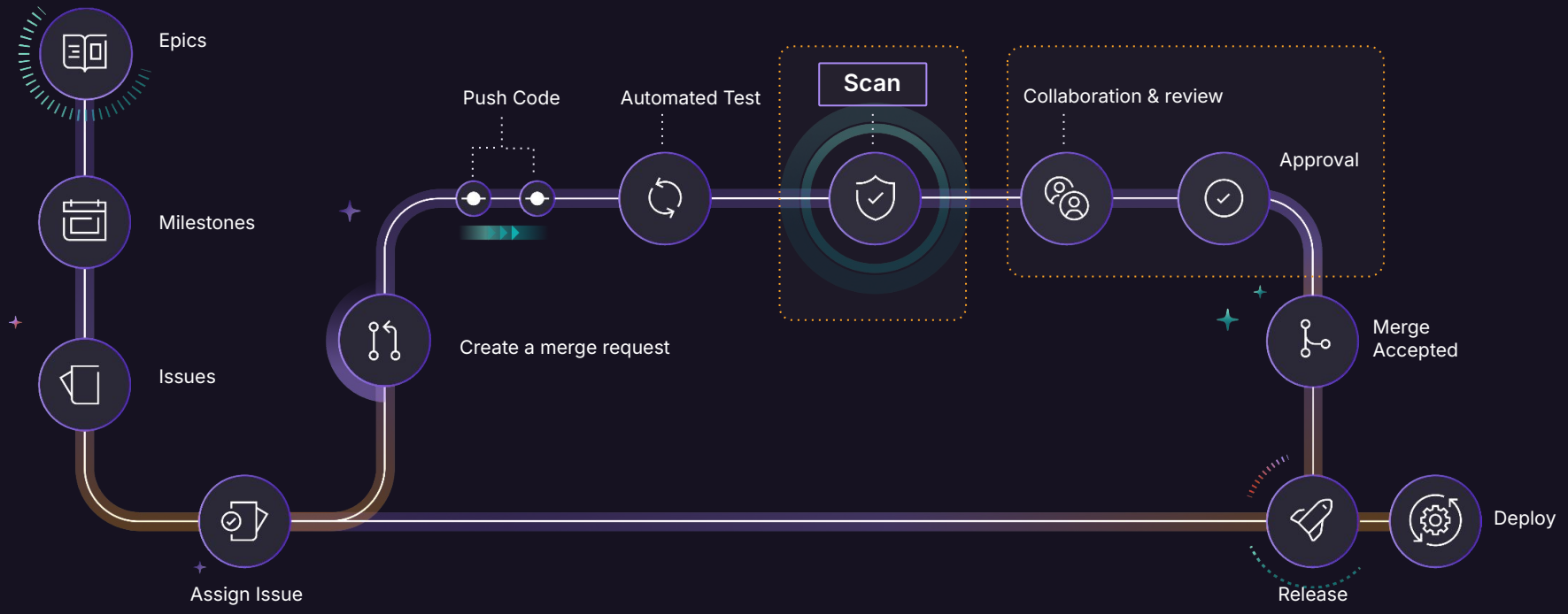
Developer Advocate

Austin, Texas, USA

@awkwardferny

GitLab Copyright

Vulnerability scans done within the pipeline



GitLab Copyright

@awkwardferny

Identify Vulnerable Software

All security tests embedded in the CI/CD pipeline and results shown in the MR

SAST
Scan application source code and binaries

DAST
Analyze web applications for runtime threats

Dependency Scanning
Analyze external dependencies

IaC Scanning
Scan infrastructure files for insecure practices

Secret Detection
Check for credentials in code commits

Container Scanning
Look for knowns security vulnerabilities

API Security
Analyze APIs for runtime vulnerabilities

Fuzz Testing
Use malformed data to measure app stability

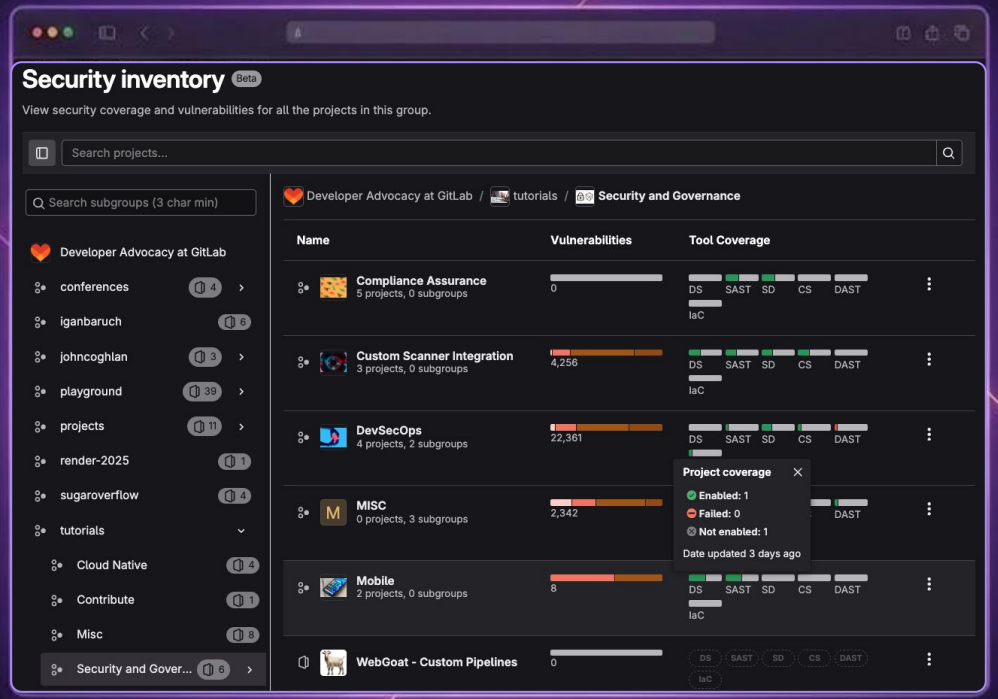
Bring your own Tool
Easily integrate your existing security tools

Extract More Value
Use GitLabs policies, reporting, and guardrails

Remote SAST Scanning
SAST can scan in the IDE before committing

Security Inventory

Visualize your assets, understand coverage gaps, and triage risks to your organization



@awkwardferny

Merge request approval policies

Security Scans

Requires approval for vulnerability violations based on extremely granular criteria:

- Status (new vs pre-existing)
- Severity
- Number of vulnerabilities
- Scan type (SAST, DAST, etc)
- Age of the vulnerability
- Whether or not a fix is available
- Whether or not a false positive is detected

License Compliance

Requires approval for project dependencies for approved and denied licenses defined by custom policies

License compliance policies allow legal teams to require approval either:

- For licenses that are explicitly denied
- Or for any license that has not been explicitly approved.

Approval can be required either for licenses that are newly detected or pre-existing or both.

All Merge Requests

You can configure the settings for merge request approvals to ensure the approval rules meet your use case:

- Prevent approval by author
- Prevent approvals by users who add commits
- Prevent editing approval rules in merge requests
- Require user re-authentication (password or SAML) to approve
- Code Owner approval removals
- Keep approvals
- Remove all approvals
- Remove approvals by Code Owners if their files changed

Required Approvals

The merge request can be blocked unless it is approved by defined eligible approvers:

- Role-based approvers (Developer, Maintainer, etc)
- Group-based approvers (Only the security team)
- Individual named approvers
- Approvers who are not an author or committer in the merge request

GitLab Copyright

Execution policies

Condition

Enforced Action

Scan Execution Policy

Policy Triggers

On a schedule (eg. every day at 4:00)

When a pipeline runs on:

- Any branch
- Specific branches
- Protected branches
- The default branch

Require GitLab Scans

- GitLab pipeline security scan (SAST, DAST, etc)
- GitLab Production / runtime container scan

Pipeline Execution Policy

Policy Triggers

When a pipeline runs on:

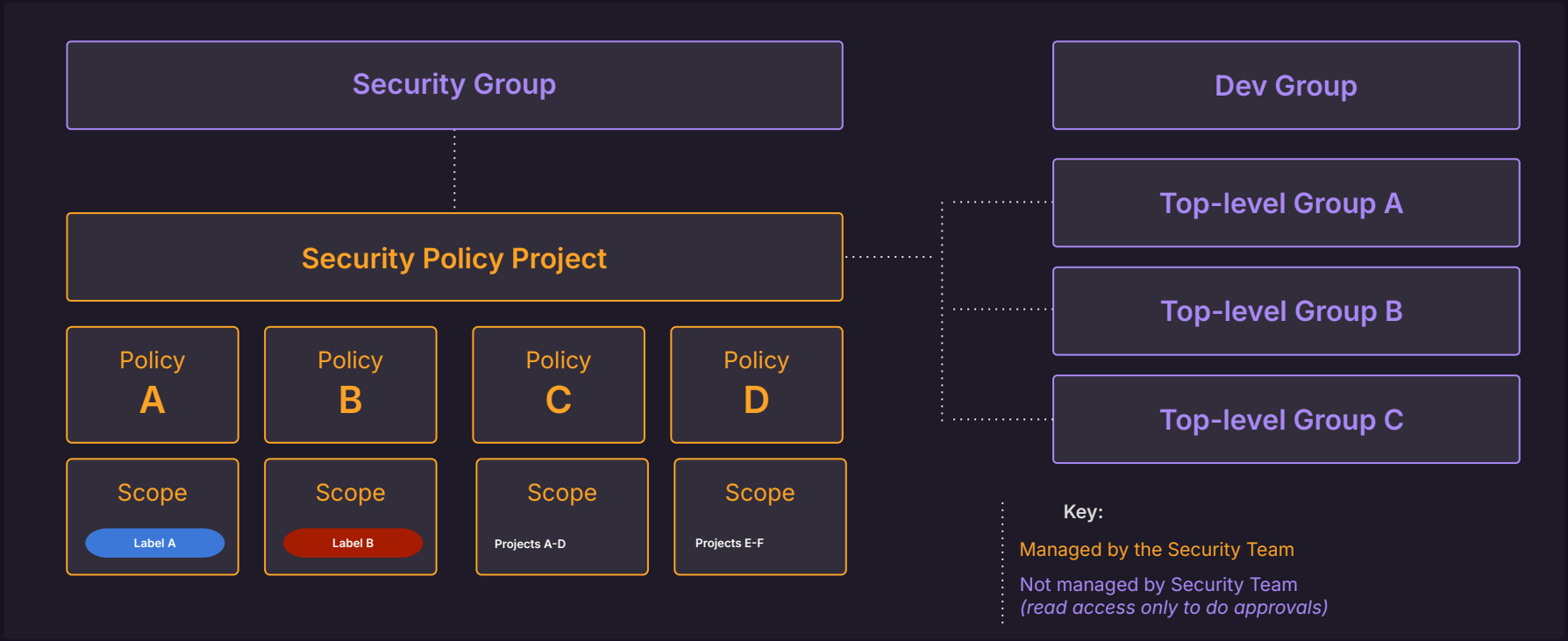
- Any branch
- Specific branches
- Protected branches
- The default branch

Require Custom CI Jobs/Scripts

- Any custom-defined CI job
- Can inject or override

GitLab Copyright

Security Policies Enforcement Model



GitLab Copyright

GitLab Security Analyst Agent

A specialized AI assistant that helps with vulnerability management and security analysis workflows in GitLab.

Assists with:

- Vulnerability triage
- Risk assessment
- False positive identification
- Compliance management
- Security reporting
- Remediation planning
- Security workflow automation

GitLab Copyright

GitLab AI: Smarter Security Analysis

SAST False Positive Detection

- Leverages AI to automatically identify and label probable false positives in Static Application Security Testing (SAST) results.
- Reduces noise, allowing security teams to focus on genuine threats.

Agentic SAST Vulnerability Resolution

- Utilizes generative AI to understand vulnerability context and automatically generate merge requests with proposed fixes.
- Accelerates remediation, streamlining the security workflow.

GitLab Copyright

GitLab

Demo

© GitLab Inc.

Built Together. Better Together.

- Elasticsearch powers GitLab Advanced Search: code, issues, and merge requests across every project
- GitLab deployment pipeline logs flow directly into Elasticsearch for real-time observability
- Elastic's native GitLab integration ingests API, audit, and auth logs into Elastic SIEM
- One shared foundation: from developer search to security operations

GitLab Copyright